

Podcast 11 — Security Detection & Audit

Podcast 11 — Security Detection & Audit

Length target: 15 min **Repo references:** `domain-1-organizational/19-security-findings.md` , `36-macie.md` , `22-aws-audit-manager.md` , `23-aws-artifact.md`

Topic & Scope

The six security-detection services (GuardDuty, Inspector, Security Hub, Detective, Macie, Audit Manager) all sound similar. The exam asks which one detects what.

Service Coverage Depth

Deep: - GuardDuty — threat detection (logs / DNS / VPC Flow Logs / S3 access) - Inspector — vulnerability scanning (EC2 / containers / Lambda) - Security Hub — aggregator + compliance posture - Macie — S3 sensitive data discovery (PII, PHI) - Detective — investigation (causal graph from existing findings)

Brief: - Audit Manager (continuous compliance evidence) - Artifact (download AWS compliance reports)

Structured Outline

1. **Open (30s)** — “Six security services, six jobs. Confusion costs you exam points. Let’s separate them cold.”
2. **GuardDuty (3 min)** — managed threat detection from VPC Flow Logs + DNS + CloudTrail + S3 + EKS audit + Lambda + RDS; ML-based; integrates with Security Hub
3. **Inspector (2.5 min)** — vulnerability scanning of EC2 (SSM agent), ECR images, Lambda functions; CVE-based + network reachability
4. **Security Hub (3 min)** — aggregator: pulls findings from GuardDuty + Inspector + Macie + IAM Access Analyzer + Firewall Manager + third-party; CIS / PCI / AWS Foundational compliance standards
5. **Macie (2 min)** — S3 sensitive data discovery (managed PII/PHI/credentials regex + ML); job-based scanning
6. **Detective (2 min)** — graph-based investigation, ingests GuardDuty findings + CloudTrail + VPC Flow Logs, NOT a detector itself
7. **Audit Manager + Artifact (1.5 min)** — Audit Manager auto-collects evidence for SOC2/PCI/HIPAA frameworks; Artifact downloads AWS’s own compliance docs
8. **Rapid-Fire Trap Drill (60s)**

Must-Mention Exam Tips

- GuardDuty data sources: VPC Flow Logs, DNS query logs, CloudTrail logs, S3 data events, EKS audit logs, Lambda invocation, RDS login attempts
- GuardDuty findings: crypto-mining, reconnaissance, credential exfiltration, suspicious S3 access
- Inspector scans: EC2 (via SSM agent), ECR images at push or continuously, Lambda function code + dependencies
- Inspector uses CVE database + checks for network reachability
- Security Hub aggregates findings from many sources into one console + supports the AWS Foundational Security Best Practices, CIS, PCI-DSS, NIST standards
- Security Hub auto-enables across Org via designated administrator
- Macie discovers PII / PHI / credentials in S3 buckets with managed identifiers + custom regex
- Macie runs discovery jobs — not continuous by default
- Detective builds a behavior graph from CloudTrail + VPC Flow Logs + GuardDuty — for investigation, not detection
- Audit Manager continuously gathers evidence aligned to frameworks (SOC2, PCI, HIPAA, GDPR)
- Artifact downloads AWS's compliance reports (SOC, PCI, ISO) — for your auditors
- All of GuardDuty / Inspector / Macie / Security Hub support org-wide enablement via delegated admin

Must-Mention Exam Traps

- EXAM TRAP: Detective does NOT detect threats — it investigates findings from others (GuardDuty mainly)
- EXAM TRAP: Macie scans S3 only — not RDS, not EFS
- EXAM TRAP: Inspector is now agentless for ECR + Lambda; EC2 needs SSM agent
- EXAM TRAP: Security Hub does NOT generate its own findings (mostly) — it aggregates + runs compliance checks
- EXAM TRAP: GuardDuty does NOT require agents — it reads logs
- EXAM TRAP: GuardDuty must be enabled per-Region — for org-wide use delegated administrator
- EXAM TRAP: Audit Manager ≠ Artifact — Audit Manager builds YOUR compliance evidence; Artifact provides AWS's compliance docs
- EXAM TRAP: GuardDuty finding format ≠ Security Hub finding format — Security Hub normalizes via ASFF (AWS Security Finding Format)
- EXAM TRAP: Inspector v2 replaced classic Inspector — exam may still use old name
- EXAM TRAP: Macie's job cost depends on data volume scanned — full-bucket repeated scans get expensive
- EXAM TRAP: Some services overlap — e.g., GuardDuty + Macie both detect S3 anomalies, but with different scope
- EXAM TRAP: Security Hub controls have to be DISABLED if not relevant — otherwise they show as failed

Key Decision Matrix

Need	Pick
Detect unusual API activity / crypto-mining / credential abuse	GuardDuty
Scan EC2 / containers / Lambda for CVEs	Inspector
Discover PII in S3 buckets	Macie
Aggregate all security findings + compliance posture	Security Hub
Investigate a GuardDuty finding — who did what, when, where	Detective
Continuously collect compliance evidence for SOC2 audit	Audit Manager
Download AWS's SOC2 / ISO / PCI report	Artifact
Compliance posture against PCI-DSS / CIS / NIST	Security Hub standards

Tone & Style

- Open with the “six look alike, six are different” framing
- For each service: data source + one example finding/output
- Repeat “Macie = S3 only” — common trap

Rapid-Fire Closer

“Detect crypto-mining?” — “GuardDuty.” “CVEs in containers?” — “Inspector.” “PII in S3?” — “Macie.” “Investigate GuardDuty finding?” — “Detective.” “PCI-DSS compliance dashboard?” — “Security Hub.” “Download SOC2 report?” — “Artifact.”